

Atores, ataques e criptografia

ENSA 3 — Conceitos de segurança de rede · 18 min de leitura · vídeo-aula 2 min · nível básico

Nesta aula vai aprender a

- ✓ Reconhecer atores de ameaça e ferramentas
- ✓ Descrever vulnerabilidades de IP, TCP e UDP
- ✓ Explicar hash, cifra simétrica e assimétrica

Como estudar esta aula

1 Veja a vídeo-aula na app (2 min).	2 Leia este PDF com calma e sublinhe o que é importante.	3 Faça os exercícios da pág. 6.	4 Confira as soluções na pág. 9.
---	---	---	--

ANTES DESTA AULA

Esta aula continua a última aula do módulo anterior (ENSA 2): **ENSA 2 · Aula 1 de 1 — OSPFv2 de área única**. Se ainda não a fez, comece por lá; se já a fez, releia os objetivos dela e confirme que os domina.

Índice

1. Quem ataca	2
2. Criptografia	2
3. Termos técnicos	3
4. Protocolos	5
5. Exercícios para fazer	6
6. Quiz	8
7. Soluções	9
8. Referências bibliográficas	10

1. Quem ataca

Ator	Motivação
Cibercriminoso	Dinheiro
Hacktivista	Causa política ou social
Estado	Espionagem, sabotagem
Interno	Vingança, descuido
Script kiddie	Curiosidade, fama

Vulnerabilidade	Ataque
IP	Spoofing de endereço, ataques ICMP, amplificação
TCP	SYN flood, reset, sequestro de sessão
UDP	Inundação UDP, ataques ao DNS
Serviços	ARP spoofing, envenenamento de DNS, DHCP falso

2. Criptografia

Técnica	Garante	Exemplos
Hash	Integridade	SHA-256
HMAC	Integridade + autenticidade	HMAC-SHA256
Cifra simétrica (mesma chave)	Confidencialidade, rápida	AES
Cifra assimétrica (par de chaves)	Confidencialidade, assinatura, troca de chaves	RSA, ECC
Diffie-Hellman	Troca segura de chaves	DH, ECDH
PKI e certificados	Identidade	Certificados X.509 (HTTPS)

ATENÇÃO

Ferramentas como Nmap, Wireshark ou Metasploit só podem ser usadas em redes próprias ou com **autorização escrita**. Usá-las em redes de terceiros é crime em muitos países.

3. Termos técnicos

O que quer dizer cada palavra técnica que aparece na aula, em linguagem simples.

Cifra (criptação) — Transformar dados legíveis em dados ilegíveis com uma chave, para só quem tem a chave os perceber. Exemplo: «OLA» cifrado pode ficar «X7#q»; sem a chave não se lê.

Ameaça — Qualquer coisa ou pessoa que pode causar dano a um sistema ou aos seus dados. Exemplo: Um vírus, um hacker ou uma inundação na sala de servidores são ameaças.

Vulnerabilidade — Fraqueza num sistema que pode ser aproveitada para o atacar. Exemplo: Um router com a palavra-passe de fábrica «admin» tem uma vulnerabilidade.

IP (Internet Protocol (protocolo da Internet)) — O protocolo da camada de rede que dá endereços aos equipamentos e leva os pacotes de rede em rede até ao destino. Exemplo: Cada pacote IP tem um endereço de origem e um de destino.

TCP (Transmission Control Protocol (protocolo de controlo de transmissão)) — Protocolo de transporte fiável: abre uma ligação, numera os dados, confirma o que chegou e reenvia o que se perdeu. Exemplo: Páginas web, e-mail e transferências de ficheiros usam TCP.

UDP (User Datagram Protocol (protocolo de datagramas do utilizador)) — Protocolo de transporte simples e rápido: envia sem abrir ligação e sem confirmar a chegada. Exemplo: Chamadas de voz, DNS e jogos online usam UDP.

Hash — Função que transforma qualquer dado num código de tamanho fixo; se o dado mudar um bit, o código muda todo. Serve para verificar integridade. Exemplo: O SHA-256 de um ficheiro descarregado confirma que não foi alterado.

Cifra simétrica — Cifra em que se usa a mesma chave para cifrar e decifrar. É rápida. Exemplo: O AES é uma cifra simétrica usada no Wi-Fi WPA2.

Python — Linguagem de programação simples e muito usada para automatizar redes. Exemplo: Um script Python com Netmiko entra por SSH em 50 routers e recolhe show version.

Spoofing (falsificação) — Falsificar um endereço (IP, MAC) ou identidade para se fazer passar por outro. Exemplo: ARP spoofing: o atacante diz que o MAC dele é o do gateway.

ICMP (Internet Control Message Protocol) — Protocolo de mensagens de controlo e erro do IP. É usado pelo ping e pelo traceroute. Exemplo: «Destination unreachable» é uma mensagem ICMP.

SYN (synchronize) — Sinal (flag) TCP usado para pedir a abertura de uma ligação. Exemplo: O primeiro segmento do PC para o servidor web leva a flag SYN.

Flooding (inundação) — Quando o switch não conhece o destino, envia a trama por todas as portas menos aquela por onde entrou. Exemplo: Uma trama para um MAC desconhecido é inundada pelas 23 outras portas do switch.

DNS (Domain Name System (sistema de nomes de domínio)) — Serviço que traduz nomes fáceis de lembrar em endereços IP, como uma lista telefônica. Exemplo: O DNS traduz `www.google.com` para `142.250.184.4`. Usa a porta 53.

ARP (Address Resolution Protocol (protocolo de resolução de endereços)) — Protocolo que descobre o endereço MAC de um equipamento a partir do seu endereço IPv4, na mesma rede local. Exemplo: O PC pergunta em broadcast «Quem tem `192.168.1.1`?» e o router responde com o seu MAC.

DHCP (Dynamic Host Configuration Protocol (protocolo de configuração dinâmica de host)) — Serviço que dá automaticamente a cada equipamento o seu endereço IP, máscara, gateway e DNS. Exemplo: Ao ligar-se ao Wi-Fi, o telemóvel recebe `192.168.1.23` do servidor DHCP. Usa UDP 67/68.

Tríade CIA (Confidentiality, Integrity, Availability) — Os três objetivos da segurança: confidencialidade, integridade e disponibilidade. Exemplo: Cifrar protege a confidencialidade; o hash, a integridade; a redundância, a disponibilidade.

Cifra assimétrica (criptografia de chave pública) — Cifra com um par de chaves: uma pública (que se pode dar a todos) e uma privada (secreta). Exemplo: O RSA cifra com a chave pública do servidor e só a chave privada dele decifra.

Certificado digital — Documento eletrónico que associa uma chave pública a uma identidade, assinado por uma entidade de confiança. Exemplo: O certificado do site do banco é emitido por uma autoridade de certificação.

HTTPS (HTTP Secure) — HTTP protegido com cifra TLS, para ninguém ler nem alterar os dados pelo caminho. Exemplo: O cadeado no navegador indica HTTPS, na porta TCP 443.

Reconhecimento (reconnaissance) — Fase inicial de um ataque em que se recolhe informação sobre o alvo. Exemplo: Usar nmap para descobrir que portas estão abertas no servidor.

Wireshark — Programa que captura e mostra todos os pacotes que passam numa interface, camada a camada. Exemplo: Com o Wireshark vê-se o three-way handshake TCP ao abrir um site.

Rede — Dois ou mais equipamentos ligados entre si para partilhar informação e recursos. Exemplo: Os computadores e a impressora de um escritório ligados ao mesmo switch formam uma rede.

AAA (Authentication, Authorization, Accounting) — Modelo de controlo de acesso: autenticação (quem é), autorização (o que pode fazer) e contabilização (o que

fez). Exemplo: O administrador entra no router com a conta do servidor central e tudo o que faz fica registado.

Permissão — Autorização dada a um utilizador ou grupo para fazer algo com um recurso: ler, alterar, apagar. Exemplo: O grupo Contabilidade tem permissão de leitura na pasta Faturas.

4. Protocolos

ARP — Address Resolution Protocol (protocolo de resolução de endereços)

camada OSI 2 · TCP/IP: Acesso à rede

Descobre o endereço MAC que corresponde a um endereço IPv4 na mesma rede local. Sem ARP o PC sabe o IP de destino mas não consegue montar a trama Ethernet. (O antigo RARP fazia o contrário e foi substituído pelo DHCP.)

ICMP — Internet Control Message Protocol (protocolo de mensagens de controlo)

camada OSI 3 · TCP/IP: Internet · portas: — (protocolo IP 1)

Envia mensagens de erro e de diagnóstico sobre a entrega de pacotes IPv4. É usado pelo ping e pelo traceroute.

TCP — Transmission Control Protocol (protocolo de controlo de transmissão)

camada OSI 4 · TCP/IP: Transporte · portas: 0–65535 (ex.: 80, 443, 22, 445)

Garante que os dados chegam completos, sem erros e pela ordem certa. É usado quando não se pode perder nada: páginas web, e-mail, ficheiros.

UDP — User Datagram Protocol (protocolo de datagramas do utilizador)

camada OSI 4 · TCP/IP: Transporte · portas: 0–65535 (ex.: 53, 67/68, 69, 123, 161)

Envia dados rapidamente, sem ligação nem confirmações. É usado quando a rapidez importa mais do que perder um pedaço: voz, vídeo, DNS, jogos.

HTTPS/TLS — HTTP Secure com Transport Layer Security (HTTP seguro)

camada OSI 7 · TCP/IP: Aplicação · transporte: TCP · portas: TCP 443 (UDP 443 com HTTP/3)

É o HTTP protegido por TLS: cifra os dados e prova a identidade do site com um certificado digital. O cadeado no navegador indica que a ligação é HTTPS.

DNS — Domain Name System (sistema de nomes de domínio)

camada OSI 7 · TCP/IP: Aplicação · transporte: TCP e UDP · portas: UDP 53 (consultas), TCP 53 (respostas grandes e transferências de zona)

Traduz nomes fáceis de lembrar (www.google.com, fs01.clinica.local) em endereços IP. É a «lista telefónica» da Internet.

5. Exercícios para fazer

Os 10 exercícios obrigatórios desta aula. Responda à mão nas linhas; as soluções, com a resolução, estão no fim deste PDF. Na app pode fazer exercícios novos sem fim.

1. O que significa **DHCP** (Dynamic Host Configuration Protocol (protocolo de configuração dinâmica de host))?

- ☐ **A)** Serviço que dá automaticamente a cada equipamento o seu endereço IP, máscara, gateway e DNS.
- ☐ **B)** Protocolo de transporte fiável: abre uma ligação, numera os dados, confirma o que chegou e reenvia o que se perdeu.
- ☐ **C)** Trama Ethernet maior que o normal (até cerca de 9000 bytes), usada em redes de armazenamento.
- ☐ **D)** O endereço completo de um recurso na Web: protocolo, nome do servidor e caminho.

2. Em que camada OSI trabalha **HTTPS/TLS**?

- ☐ **A)** 7 — Aplicação
- ☐ **B)** 3 — Rede
- ☐ **C)** 1 — Física
- ☐ **D)** 2 — Ligação de dados

3. O que significa **DNS** (Domain Name System (sistema de nomes de domínio))?

- ☐ **A)** Regra de NAT que envia as ligações que chegam a uma porta do IP público para um servidor interno.
- ☐ **B)** Serviço que traduz nomes fáceis de lembrar em endereços IP, como uma lista telefónica.
- ☐ **C)** Conjunto de redes geridas por uma só organização, com uma política de encaminhamento comum.
- ☐ **D)** Tipo de interface antiga de router para ligações WAN ponto a ponto.

4. O que quer dizer a sigla **Reconhecimento**?

- ☐ **A)** distance vector
- ☐ **B)** Domain Name System (sistema de nomes de domínio)
- ☐ **C)** reconnaissance
- ☐ **D)** LAP / AP leve

5. O que quer dizer a sigla **Flooding?**

- ☐ **A)** Logical Link Control (controlo lógico da ligação)
- ☐ **B)** Terminal Access Controller Access-Control System Plus
- ☐ **C)** Institute of Electrical and Electronics Engineers
- ☐ **D)** inundação

6. Que porta usa **ICMP?**

- ☐ **A)** — (protocolo IP 89; multicast 224.0.0.5 e 224.0.0.6)
- ☐ **B)** — (protocolo IP 1)
- ☐ **C)** TCP 443 (HTTPS)
- ☐ **D)** UDP 514 (TCP 514/6514 com TLS em algumas implementações)

7. O que quer dizer a sigla **UDP?**

- ☐ **A)** VLANs permitidas
- ☐ **B)** User Datagram Protocol (protocolo de datagramas do utilizador)
- ☐ **C)** link-state
- ☐ **D)** Unshielded Twisted Pair (par entrançado não blindado)

8. O que significa **Cifra assimétrica (criptografia de chave pública)?**

- ☐ **A)** Processo em que as duas pontas de um cabo combinam sozinhas a melhor velocidade e duplex.
- ☐ **B)** Opção do Windows que permite ver e ser visto por outros computadores na rede local.
- ☐ **C)** Ataque em que alguém se mete no meio da comunicação entre duas partes para ler ou alterar os dados.
- ☐ **D)** Cifra com um par de chaves: uma pública (que se pode dar a todos) e uma privada (secreta).

9. O que quer dizer a sigla **DNS?**

- ☐ **A)** Internet Control Message Protocol
- ☐ **B)** YAML Ain't Markup Language
- ☐ **C)** binary digit (dígito binário)
- ☐ **D)** Domain Name System (sistema de nomes de domínio)

10. Em que camada OSI trabalha ARP?

- ☐ **A)** 4 — Transporte
- ☐ **B)** 3 — Rede
- ☐ **C)** 1 — Física
- ☐ **D)** 2 — Ligação de dados

6. Quiz

4 perguntas. Para concluir a aula na app precisa de 70% no quiz.

1. O que garante integridade?

- ☐ **A)** Hash
- ☐ **B)** Cifra simétrica
- ☐ **C)** NAT
- ☐ **D)** VLAN

2. Que cifra usa a mesma chave dos dois lados?

- ☐ **A)** Simétrica
- ☐ **B)** Assimétrica
- ☐ **C)** Hash
- ☐ **D)** PKI

3. Um SYN flood ataca...

- ☐ **A)** O handshake TCP
- ☐ **B)** O DNS
- ☐ **C)** O cabo
- ☐ **D)** O Wi-Fi

4. Os certificados digitais ajudam a provar a identidade de um servidor.

- ☐ Verdadeiro ☐ Falso

Porquê? _____

7. Soluções

Exercícios

1. Resposta: A) Serviço que dá automaticamente a cada equipamento o seu endereço IP, máscara, gateway e DNS.

DHCP: Serviço que dá automaticamente a cada equipamento o seu endereço IP, máscara, gateway e DNS.

Exemplo: Ao ligar-se ao Wi-Fi, o telemóvel recebe 192.168.1.23 do servidor DHCP. Usa UDP 67/68.

2. Resposta: A) 7 — Aplicação

HTTPS/TLS → camada 7 — Aplicação (TCP/IP: Aplicação). É o HTTP protegido por TLS: cifra os dados e prova a identidade do site com um certificado digital. O cadeado no navegador indica que a ligação é HTTPS.

3. Resposta: B) Serviço que traduz nomes fáceis de lembrar em endereços IP, como uma lista telefónica.

DNS: Serviço que traduz nomes fáceis de lembrar em endereços IP, como uma lista telefónica.

Exemplo: O DNS traduz www.google.com para 142.250.184.4. Usa a porta 53.

4. Resposta: C) reconnaissance

Reconhecimento = reconnaissance. Fase inicial de um ataque em que se recolhe informação sobre o alvo.

5. Resposta: D) inundação

Flooding = inundação. Quando o switch não conhece o destino, envia a trama por todas as portas menos aquela por onde entrou.

6. Resposta: B) — (protocolo IP 1)

ICMP: porta — (protocolo IP 1), transporte —.

7. Resposta: B) User Datagram Protocol (protocolo de datagramas do utilizador)

UDP = User Datagram Protocol (protocolo de datagramas do utilizador). Protocolo de transporte simples e rápido: envia sem abrir ligação e sem confirmar a chegada.

8. Resposta: D) Cifra com um par de chaves: uma pública (que se pode dar a todos) e uma privada (secreta).

Cifra assimétrica: Cifra com um par de chaves: uma pública (que se pode dar a todos) e uma privada (secreta).

Exemplo: O RSA cifra com a chave pública do servidor e só a chave privada dele decifra.

9. Resposta: D) Domain Name System (sistema de nomes de domínio)

DNS = Domain Name System (sistema de nomes de domínio). Serviço que traduz nomes fáceis de lembrar em endereços IP, como uma lista telefónica.

10. Resposta: D) 2 — Ligação de dados

ARP → camada 2 — Ligação de dados (TCP/IP: Acesso à rede). Descobre o endereço MAC que corresponde a um endereço IPv4 na mesma rede local. Sem ARP o PC sabe o IP de destino mas não consegue montar a trama Ethernet. (O antigo RARP fazia o contrário e foi substituído pelo DHCP.)

Quiz — chave de respostas**1. Resposta:** A) Hash

Hash.

2. Resposta: A) Simétrica

Simétrica (AES).

3. Resposta: A) O handshake TCP

Esgota as ligações meio abertas.

4. Resposta: Verdadeiro

Assinados por uma autoridade (PKI).

8. Referências bibliográficas

1. ODOM, Wendell. CCNA 200-301 Official Cert Guide, Volume 2. 2. ed. Hoboken: Cisco Press, 2024.
2. NIST. SP 800-63B: Digital Identity Guidelines – Authentication and Lifecycle Management. Gaithersburg: NIST, 2017.
3. KENT, S.; SEO, K. RFC 4301: Security Architecture for the Internet Protocol. IETF, 2005.